

PROFESSIONAL SECURITY ASSESSMENT REPORT.
FROM VULNERABILITY TO COMPLIANCE: SECURING
LEGACY SYSTEM AT APEX HEALTHCARE SOLUTIONS.

PREPARED BY;

1. IWUJI, DANIEL MMESOMA.
2. OLAOPA, DASOLA DEBORAH.
3. ANAYO, CHIDERA.
4. OTALI, PRECIOUS CHIBUZOR.
5. OLUGBAMI, ADEMOLA MOSES.
6. OLUEBUBECHUKWU, PRECIOUS
ANAJEMBA.
7. AKINBO, IFEOLUWA DAVID.
8. APAM, CHIKAODILI JOY.
9. DISU, OYINLOLA EMMANUEL.
10. CHRISTIANA, MICHAEL.
11. HELEN, ONYEUKWU.

GROUP NO. 37

TS ACADEMY PHOENIX COHORT.

JULY 18th, 2026.

TABLE OF CONTENTS

1. EXECUTIVE SUMMARY.....	3
2. VULNERABILITY FINDINGS.....	4
3. RISK ASSESSMENT.....	5
4. SECURITY CONTROLS.....	5
5. HOW THE RECOMMENDED CONTROLS REDUCE RISK.....	5-6
6. GRC POLICY RECOMMENDATION.....	6-7
7. CONCLUSION.....	7

LIST OF TABLES

Table 1. Vulnerability Identification.....	4
Table 2. Risk Assessment.....	5
Table 3. Security Controls.....	5

1. EXECUTIVE SUMMARY.

This security assessment was conducted to analyze the vulnerabilities found in Apex Healthcare Solutions systems and also to provide practical Government Risk and Compliance (GRC) Policy recommendations to help mitigate the vulnerabilities. Two legacy systems, Kioptrix and Metasploitable2 were discovered running in the company's environment. During the assessment six major vulnerabilities were identified in these systems. They are; Buffer Overflow, Weak Cipher Suite, Privilege Escalation, Samba Badlock (SMB), Unencrypted Telnet Server, and rsh Service Detection. These vulnerabilities could allow attackers to gain unauthorized access, steal sensitive information, intercept network traffic, or compromise critical systems. The vulnerabilities were further evaluated based on their potential impact, likelihood and risk rating.

To reduce these risks, it is recommended that Apex Healthcare Solutions implement regular patch management, replace insecure services with secure alternatives, enforce strong authentication, restrict unnecessary network services, and conduct continuous vulnerability assessments. Strengthening security policies and employee awareness will further improve the organization's overall security posture.

Overall, the assessment shows that while the systems contain significant security weaknesses, implementing the recommended controls and policies will greatly reduce cyber risks and enhance the protection of sensitive healthcare information.

2. VULNERABILITY IDENTIFICATION.

Table 1. Vulnerability Identification.

S/N	Vulnerability Name	Affected Service	Brief Description	Potential Attacker Goal
1.	Samba Badlock (metasploitable2)	Samba, port 445/TCP/CIFS	It is a high-profile security flaw which affects Samba; an open-source file and print sharing software and Microsoft Software. The version of samba found in the company's system runs on Linux and Unix server, and the remote host is affected by a flaw known as a badlock, that exists in the security protocols due to improper authentication negotiation over Remote Procedure Control (RPC)	Interception of traffic on the server in order to gain access to confidential information.
2.	Unencrypted Telnet Server (metasploitable2)	Port 23/TCP/Telnet	Telnet is a network protocol that allows a user to remotely access and control another computer over the internet or a Local Area Network (LAN). Using telnet server over an unencrypted channel is not recommended. Login IDs, passwords are transferred in clear text which paves way for a remote Man-in-the-middle attack.	Eavesdropping on communication session between telnet server and client, access to credentials and other sensitive information, modification of traffic between client and server.
3.	RSH Service Detection (metasploitable2)	Port 512/TCP/RSH	Data passed between rsh server and client is in clear text, no encryption. A threat actor can exploit this vulnerability to sniff passwords and login IDs. It may allow poorly authenticated logins without passwords, IP spoofing to bypass authentication.	Access to passwords, login IDs and IP spoofing.
4.	Buffer Overflow (kioptrix)	Port 22/TCP/SSH, Network Daemon	This happens when a program accepts more data than it was allotted. A buffer overflow exists in the daemon when the Andrew File System (AFS) token is enabled on the system. For instance, if 16 characters are allotted to Apex Healthcare Solutions system as the maximum but it was later discovered that the system received more than what was allotted to it. This will cause overflow into the system, which could eventually crash the whole solutions system.	Remote root exploit.
5.	Weak Cipher Suite (kioptrix)	Web login portals, port 443/TCP/www	Weak Cipher Suite can be exploited by attackers to decrypt sensitive communications, perform man-in-the-middle attacks or even compromise data integrity through various cryptographic attacks including brute-force decryption and padding oracle vulnerabilities.	Man-in-the-middle attack, brute force attack to gain access to the company's system.
6.	Privilege escalation (kioptrix)	Linux kernel, SUID binaries	This usually occurs after an attacker has already gained initial access through another vulnerability, such as a vulnerable web application, a weak password, or a network service exploit. When this happens, an attacker can go from been normal user to becoming a root use	To gain complete control of the apex healthcare solution system

3. RISK ASSESSMENT.

Table 2. Risk Assessment.

S/N	VULNERABILITY	LIKELIHOOD	IMPACT	RISK RATING
1.	SAMBA BADLOCK	High	Medium	High
2.	UNENCRYPTED TELNET SERVER	Medium	High	Medium
3.	RSH SERVICE DETECTION	High	High	High
4.	BUFFER OVERFLOW	High	High	High
5.	WEAK CIPHER SUITE	Medium	High	Medium
6.	PRIVILEGE ESCALATION	Medium	High	High

Qualitative Risk Assessment was used to rate the risks above (High, Medium, Low).

- I. **Likelihood:** It was rated based on the documented events, showing the same vulnerabilities have been exploited by some threat actors.
- II. **Impact:** The vulnerabilities are rated based on the amount of damage it could cause the company. For instance, unencrypted telnet server exposes the company to legal actions if exploited by a threat actor. Low (means the impact is not so much), Medium (the impact is not negligible), High (Apex Healthcare Solutions is at a great risk)
- III. **Risk Rating:** It was assessed by correlating the likelihood with impact.

4. SECURITY CONTROLS.

Table 3. Security Controls.

S/N	VULNERABILITY	RECOMMENDED CONTROL
1.	SAMBA BADLOCK	Upgrade Samba version
2.	UNENCRYPTED TELNET SERVER	Disable telnet server and replace with Secure Shell (SSH)
3.	RSH SERVICE DETECTION	Disable service and use SSH.
4.	BUFFER OVERFLOW	Updating security patches, using firewalls, enable exploit mitigation features on the system
5.	WEAK CIPHER SUITE	Disable all weak cipher suites, enable authenticated encryption, reconfigure the affected application.
6.	PRIVILEGE ESCALATION	Keep the operating system and kernel, fully passed restrict right permission on files in your system, using endpoint detection and response (EDR)

5. HOW THE RECOMMENDED CONTROLS REDUCE RISKS.

The security Control recommended goes a long way in stopping hackers from getting in, or limit the damage if they do. For instance, updating outdated Telnet to SSH stops hackers from stealing passwords and other credentials from the company because the SSH scrambles or encrypts the company's data while it travels. Also, updating Samba fixes known bugs, patching up holes so bad for that the attacker can't sneak through them.

Applying security patches fixes known software flaws, firewalls help block malicious traffic, and exploit mitigation features prevent attackers from executing malicious code, reducing the risk of system compromise.

Disabling weak cipher suites and enabling strong encryption protect data during transmission, making it much harder for attackers to intercept or decrypt sensitive information.

Keeping the operating system updated, restricting file permissions, and using Endpoint Detection and Response (EDR) help prevent attackers from gaining administrator privileges and detect suspicious activities early.

6. GRC POLICY RECOMMENDATION.

The following GRC policies are recommended for Apex Healthcare Solutions;

- I. Patch Management Policy:** A patch is a software update that fixes a security problem. When software companies discover any weakness in their product, they release a patch which is basically a repair to close the hole. Patch management policy is the company's official rule that says; we must always update all our software and systems so that any known vulnerability is fixed before it gets exploited by an attacker.
Apex Healthcare Solutions specifically needs this policy because, the legacy systems running in the company's environment included an outdated version of Samba with a known vulnerability (samba badlock and a weak cipher suite) on an old SSL version found on both metasploitable2 and kioptrix1. Both of these exist because the software was never updated.
If Apex Health Care Solutions had a patch management policy in place, somebody would have been responsible and held accountable for regular updates. These vulnerabilities would never have existed in the first place. For a healthcare company this matters a lot because patient records are always involved.
The policy helps to mitigate, samba badlock, weak cipher suite and buffer overflow, because all three of these exist on any outdated, unpatched software.
- II. Access Control Policy:** Access control simply means controlling who is allowed to get into what. This policy ensures that not everybody has access to confidential details in the company. Access to systems and information is solely based on job title and description.
We identified privilege escalation on Kioptrix1, which means an attacker was able to go from being a normal low-level user all the way up to having full root/admin control of the system. This only happens when access levels are not properly controlled and restricted. If Apex Healthcare Solutions had a strict access control policy, no normal user would be able to escalate to admin level because these permissions would be locked down from the beginning.
The RSH Service vulnerability allowed logins without proper authentication, which is also a failure of access control.
This policy helps to mitigate, privilege escalation, rsh service detection, buffer overflow (limiting who can run/own certain programs reduces the damage a buffer overflow can do)
- III. Vulnerability Management Policy:** This policy is to ensure that the company's systems must be continuously and regularly scanned to find weaknesses, assess how dangerous they are, and fix them before any attacker finds them first. It's not a one-time thing rather it's an ongoing process that should never stop. A vulnerability management policy makes sure someone in the company is always looking out for new weaknesses before any criminal does.
Apex Healthcare Solutions need a vulnerability management policy because every single vulnerability we found, samba badlock, telnet, rsh service detection, buffer overflow, weak cipher suite and privilege escalation, existed in the system without anybody noticing or acting on it. This

is exactly what happens when there is no vulnerability management policy. There's nobody to regularly scan and check.

If Apex Healthcare Solutions had these policies, scheduled vulnerability scans would have found these issues long before a cybersecurity consulting team had to be called in. For a healthcare company handling sensitive patient records, discovering vulnerabilities after the fact is way too late. The policy helps to mitigate, samba bad luck, unencrypted telnet server, rsh service detection, buffer overflow, weak cipher suite, privilege escalation

- IV. Acceptable Use Policy:** It a rule that states what people are allowed to do with the company's systems, devices, and networks and what they are not allowed to do. It comprises lists of unauthorized software that are not to be installed, it also states that employees must not share login credentials with anyone. Also, must not use company systems outside the company or for personal or illegal activities. Unauthorized devices must not be connected to the company's network.

An Acceptable Use Policy sets the rules for how people interact with the company's technology. It sets clear boundaries so that employees understand their responsibilities in keeping the company's system safe. This helps to mitigate unencrypted telnet server, rsh service detection, weak authentication and privilege escalation.

7. CONCLUSION

This security assessment identified several vulnerabilities in the legacy systems; Kioptrix1 and Metasploitable2 that could expose Apex Healthcare Solutions to unauthorized access, data compromise, and service disruption if left unaddressed. The identified weaknesses highlight the importance of implementing effective security controls, timely patch management, secure system configurations, and strong access control mechanisms.

By applying the recommended technical controls and organizational security policies, the organization can significantly reduce its overall risk, strengthen its security posture, and improve its ability to protect sensitive healthcare information. Regular vulnerability assessments and continuous security monitoring should be maintained to ensure emerging threats are identified and addressed promptly.